CISSP Domain 5：アイデンティティとアクセス管理（IAM）

> 学習ノート（2026-10-24）。音声で読み上げられた内容を中心に、CISSP試験向けに概念・用語・具体例を整理。5.1〜5.6を収録。

Domain 5 概要：IAMの目的と全体像

組織は情報資産を**分類・カテゴリ化**し、機密性・完全性・可用性（CIA）が損なわれた場合の事業影響を評価する。これに基づき、**誰／何が、どの資産に、どの操作を行えるか**を決定する仕組みがIAMである。アクセス制御の設計は、資産の価値、事業要件、リスク、セキュリティポリシーと整合していなければならない。

IAMの対象は従業員・委託先・顧客などの**人間のID**だけでなく、サービスアカウント、ソフトウェア、IoT機器、ロボットなどの**非人間ID（マシンID）**も含む。IDの発行から変更、権限付与、監視、無効化・削除までのライフサイクルを管理する。

主要用語

用語	定義・役割	CISSPの観点
Identity（アイデンティティ）	人・プロセス・デバイス等を区別するための識別情報	**識別**と**認証**は異なる。ユーザー名を名乗るだけでは本人確認にならない
IdM / IDM（Identity Management）	IDの作成・登録・属性管理・変更・廃止などの管理	一般にIAMの一部として扱う。用語の使い分けは文献によって異なる
IAM（Identity and Access Management）	ID管理とアクセス権管理を統合したプロセス・仕組み	誰が何にアクセスできるかをライフサイクル全体で統制
Identification（識別）	「私は誰か」を提示すること	ユーザーID、アカウント名、デバイス識別子など
Authentication（認証）	主張されたIDが正しいか検証すること	パスワード、証明書、MFAなど
Authorization（認可）	認証済み主体が行える操作・利用可能な資源を決めること	最小権限、職務分掌、アクセス制御モデル
Accounting / Accountability（記録・説明責任）	誰がいつ何をしたかを記録・追跡し、責任を帰属させること	ログ、監査証跡、個人に紐づくID
AAA（Triple A）	Authentication・Authorization・Accounting	認証・認可・記録。ネットワークアクセス管理でも頻出
IAAA	Identification・Authentication・Authorization・Accountability/Accounting	教材によって末尾Aの展開に揺れがある。識別→認証→認可→記録・説明責任の順序を理解

重要：「認証に成功した＝すべての資産にアクセスできる」ではない。認証後に、対象資産と要求操作について**認可**を評価する。

5.1 資産への物理的・論理的アクセスをコントロールする

5.1.1 目的と基本的な考え方

組織の資産への閲覧・変更・移動・コピー等のアクセスを適切に制御するため、**管理的・物理的・論理的**コントロールを一貫して組み合わせる。設計根拠は、資産インベントリ、情報分類、事業要件、セキュリティモデル、アクセス制御（AC）モデル、IDライフサイクルなどにある。

分類	主な対象	例
管理的コントロール	人の行動や組織的な判断を統制	ポリシー、アクセス承認手順、教育、職務分掌、定期的権限レビュー
物理的コントロール	人・機器の物理的な接近や移動を制限	施錠、入退室管理、警備員、ゲート、監視カメラ
論理的（技術的）コントロール	システム内の情報フローや操作を制限	ACL、RBAC、認証、ファイアウォール、ファイル権限

ユーザー操作（キーストローク、マウスクリック、センサーの検知等）が情報フローを生み、ソフトウェアのプロセスが別の操作を引き起こす場合もある。**ユーザー／主体には非人間エンティティも含まれる**点に注意。

5.1.2 アクセス制御（Access Control：AC）の基本

アクセス制御は、事業上およびセキュリティ上の要件に基づき、資産へのアクセスを**許可・制限**する手段。ISO/IEC 27000シリーズやNISTの文書で定義・ガイダンスが示される。読み上げに登場した規格番号は原文の表記に揺れがある可能性があるため、暗記時は**ISO/IEC 27000シリーズの基本概念**と**NISTのアクセス制御関連ガイダンス**を優先して押さえる。

オブジェクト・サブジェクト・アクセス

概念	定義	例
Subject（サブジェクト／主体）	オブジェクトへのアクセスを要求する人、プロセス、デバイスなど	従業員、実行中のアプリ、サービスアカウント、IoT機器
Object（オブジェクト／客体）	アクセス制御によって保護される情報資産・リソース	ファイル、データベース、レコード、API、プリンター
Access（アクセス）	主体が客体に対して行う操作	作成・読取・更新・削除（CRUD）、共有・保存・アーカイブ・移動

基本構造： サブジェクト → アクセス要求（操作） → アクセス制御による認可判断 → オブジェクト

具体例：リモートデータベースへのアクセス

1. ユーザーが端末でアプリケーションを起動する。
2. OSがアプリケーションや関連スレッド／プロセスを管理する。
3. プロセスがシステムコールやネットワークサービスを通じてサーバー上のデータベースに接続を要求する。

4. サーバーが接続要求とデータ操作要求を評価し、認証・認可の結果に応じて許可または拒否する。
5. 必要に応じて操作内容をログに記録する。

ここでは**人間のユーザーと、代理で操作を行うプロセスの両方が主体になり得る。**アクセス制御はログイン時だけでなく、個々の操作・リソースに対して適用される。

5.1.3 IAM管理の選択肢

IAM管理は、**誰がアクセス権の付与・変更・取消を管理するか**という責任配置の違いで整理できる。

方式	管理主体	具体例	メリット	課題
集中管理（Centralized）	中央のIAM部門・統一システム	全社Microsoft Entra ID、中央IAMチームが社員権限を統括	ポリシー統一・監査容易・退職時の一括停止	単一障害点、業務部門の細かなニーズに追随しにくい
分散管理（Decentralized）	各資産の所有者・部門管理者	SharePointの文書所有者が共有相手を設定	現場の判断が速く柔軟	権限乱立、監査・棚卸し困難
ハイブリッド	中央で基本方針、現場で範囲内の承認	全社IDは中央発行、部門フォルダ権限は部門長承認	ガバナンスと柔軟性の両立	責任分界・承認フローの設計が必要

重要：「集中・分散・ハイブリッド」は**管理責任の配置**であり、「物理・論理アクセス制御」は**何をどう制御するか**という別の分類。

5.1.4 システムとしてのアクセス制御

アクセス制御システムは管理的・物理的・論理的（技術的）統制の組合せで実装する。管理的統制（ポリシー、手順、教育、法令・規格への準拠）で方針を定め、物理・論理的統制で具体化する。**データオーナーが情報を分類・カテゴリ化し、その価値とリスクに応じて保護水準を決める**のが前提。

方式	制御対象	具体例
物理AC	人・物品・設備の物理的移動と接近	鍵、ドア、警備員、入退室ゲート、サーバールーム
論理AC	データ・アプリ・ネットワーク上の操作と情報フロー	ログイン、ACL、RBAC、DB権限、API認可
複合例	物理ゲートの動作を論理判断で制御	ICカードを読み取り、入室権限DBを照会して解錠

5.1.5 論理アクセス制御システムとFICAM

論理ACシステムは、登録済みIDに基づき、端末・通信ネットワーク・アプリ・システムソフトウェア・データなどへの操作を許可・拒否する仕組み。OS、DBMS、アプリ、ネットワーク機器、専用アクセス制御ソフトなどに組み込まれる。

FICAM（Federal Identity, Credential, and Access Management）は米国連邦政府のID・資格情報・アクセス管理の相互運用と統制を扱う枠組み。連邦政府特有の実装ガイダンスがある一方、民間のIAM設計にも参考になる。

FICAMそのものがアクセス制御製品や認証プロトコルではない。

識別管理とアクセス制御の区別：

- 識別管理（Identity Management）：**誰であるかを登録・発行・変更・廃止**し、属性と認証器の対応を維持。
- 認証（Authentication）：**現在アクセスする主体がそのIDの正当な利用者か**検証。
- 認可（Authorization）：**その主体にその操作が許されるか**決定。
- アクセス制御の実施（Enforcement）：決定を実際のシステムに適用し、許可・拒否。
- 同じ人が社内ID・銀行ID・SNS IDなど複数のデジタルIDを持つことがある。**あるシステムで認証済みでも別のシステムの利用権限は自動付与されない。**

5.1.6 PACS（Physical Access Control System）

PACSは**人・物品・機器が定められた境界や入口を通過することを認証・認可に基づいて管理**する仕組み。例：入館ゲート、電気錠、社員証リーダー、入退室履歴、サーバールームのアクセス制御。

- 例：社員証提示→カード識別→ID・権限・時刻・エリアを確認→解錠／拒否→入退室ログ記録。
- サーバー、配線室、端末、機器ラックなどの保護にも使う。
- NIST SP 800-53の**PE（Physical and Environmental Protection）**系管理策などと関連。教材の「Rev.4」は旧版なので、試験では概念を理解し、最新文書と区別する。
- **PACSは米国連邦機関に限定された技術ではない。**

5.1.7 アプリケーションとサービス

- **アプリケーション**：全従業員が同じアプリを利用しても、アクセスできるデータ・操作は異なる。例：Microsoft 365で各自のメールにはアクセスできても、他部署の機密SharePointサイトには原則アクセスできない。
- **サービス**：API、バックグラウンドジョブ、クラウドサービス、サービスアカウントなどの非人間IDにもIAMを適用。最小権限、秘密情報の保護、定期レビュー、廃止処理が必要。

5.2 識別および認証の戦略を設計する

5.2.1 概要：デジタルアイデンティティの変遷

時代（教材の整理）	特徴	代表例・重要な概念
第1期：個別ID	企業・サービスごとに別IDを作り管理。属性や更新時点がばらばら	各社独立したユーザーDB、IDのサイロ化
第2期：ソーシャルログイン・連携	既存のIDで他社サービスにログインする仕組みが普及	Google、Apple、Microsoft、Facebook、LinkedIn等。OIDC、フェデレーション
第3期：個人のデータ主権	個人がID・属性の提示範囲を制御する考え方	SSI（Self-Sovereign Identity）、分散型ID、検証可能な資格情報、ブロックチェーンの活用例

注意：3時代は教材の理解用区分であり、技術の発展が厳密に時代で分離されるわけではない。国家のデジタルID施策としてエストニア、EUのeIDAS等がある。**「推移的信頼（Transitive Trust）」を無条件の信頼連鎖と考えない。**IdPとSP/RPの信頼関係、トークンの検証が必要。

5.2.2 アイデンティティストアと関連プロトコル

Identity Store（IDストア）は、ID、属性、所属、状態、認証に必要な参照情報などを保持する保管先。例：Active Directory、LDAPディレクトリ、クラウドIDディレクトリ。**以下のプロトコルすべてが「IDストア」そのものというわけではない。**

技術	主な目的	仕組み・代表例	混同注意
LDAP	ディレクトリへのアクセス	AD/OpenLDAPのユーザー・グループ参照、更新	**IDストアへのアクセスプロトコル**
Kerberos	ネットワーク認証	KDC、TGT、サービスチケット。AD環境で利用	チケット方式。ディレクトリそのものではない
RADIUS	ネットワークAAA	Wi-Fi 802.1X、VPN、NACの認証・認可・記録	UDP 1812/1813が一般的
OAuth 2.0	委任された**認可**	アプリにAPIアクセス権を限定して付与	**OAuth単体はログイン認証規格ではない**
SAML 2.0	フェデレーション・SSO	IdPが署名付きXMLアサーションをSPへ提供	認証・属性情報を伝える
OpenID	フェデレーション認証の旧方式	OpenID 2.0等（歴史的）	OpenID Connectと区別
OpenID Connect（OIDC）	OAuth 2.0上の認証レイヤー	IDトークン（通常JWT）、RP、IdP/OP	IDトークンはAPI権限そのものではない
FIDO U2F	セキュリティキーによる追加認証	USB/NFC等のセキュリティキー	旧世代の方式
FIDO UAF	主にパスワードレス認証	ローカルの生体・PINと公開鍵	U2Fと用途が異なる
FIDO2	公開鍵ベースの認証・パスキー	**WebAuthn + CTAP**、セキュリティキー/パスキー	フィッシング耐性が強み
WebAuthn	Webアプリの公開鍵認証API	ブラウザーと認証器の連携	パスワードをサーバーへ送らない

初期の独自スクリプトで資格情報をシステム間に転送する方式は、拡張性や秘密情報漏えいの問題が生じやすい。**標準化されたフェデレーションは認証結果・トークンの検証を重視し、原則としてパスワードを各SPに配らない。**

5.2.3 クレデンシャル管理システム（CMS）

Credential（クレデンシャル）は、ID（誰か）と認証器（本人性を示すもの）を結び付ける情報。例：ユーザーに結び付けた公開鍵証明書、登録済みのセキュリティキー、認証情報。スマートカードは認証器の保管媒体となり得る。

CMS（Credential Management System）は資格情報の生成・発行・配布・更新・失効・廃止を扱う仕組み。**CSP（Credential Service Provider）**は身元証明・登録・認証器の管理などを担う主体。CSPは文脈によりクラウドサービスプロバイダーの略にもなるため注意。

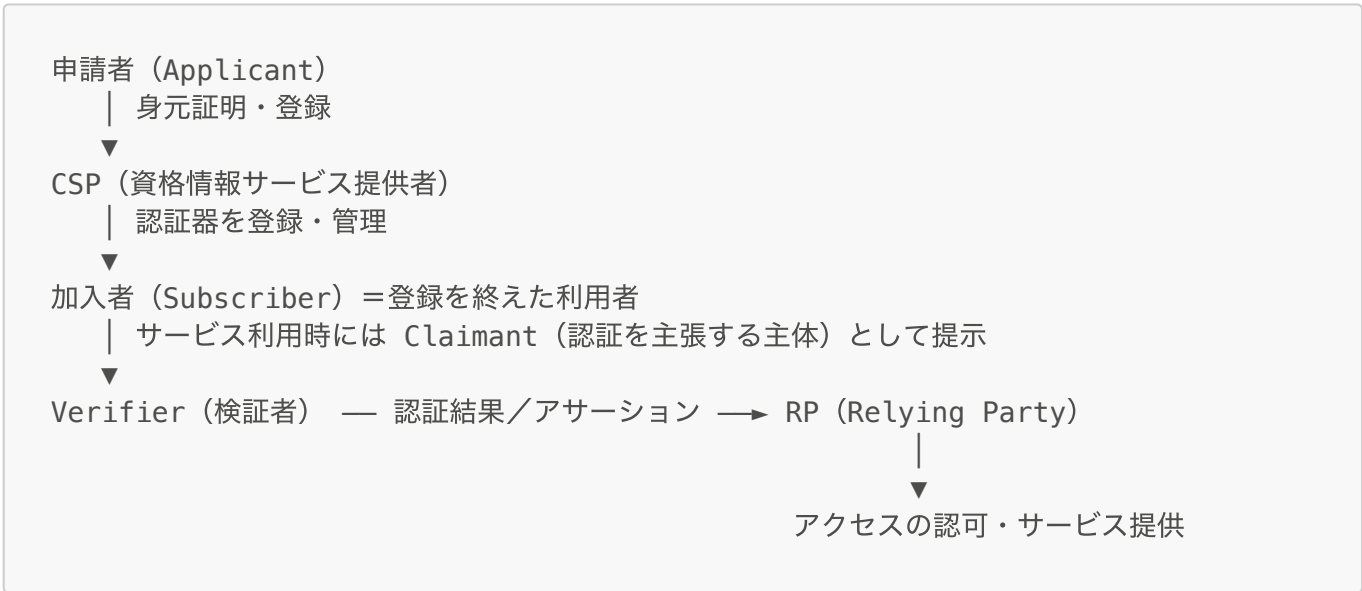
FICAMの5段階

段階	何をするか	社員証・電子証明書の例
① Sponsorship（スポンサーシップ）	組織が発行の必要性・対象を承認	人事・上長が入社と利用目的を確認
② Enrollment（登録）	身元を確認しID・属性を登録	本人確認書類を照合し社員IDを登録
③ Credential Generation（生成）	認証器・鍵などを作成	スマートカード用鍵ペア・証明書を生成
④ Issuance（発行）	正しい本人へ安全に引き渡す	カードを本人に手渡し、初期設定
⑤ Lifecycle Management（ライフサイクル管理）	更新、紛失対応、失効、再発行、廃止	退職時に証明書失効・カード停止

PKIとの関係：PKIは公開鍵証明書の信頼基盤（CA、RA、証明書、CRL/OCSP等）。ルートCAは証明書チェーンの信頼の起点。CMSは**証明書を含む資格情報の運用管理**、PKIはその実現技術の一つ。**FICAMがPKIを発明したわけではない。**

2FA/MFAとの関係：スマートカード（所持）＋PIN（知識）などの異なる要素を組み合わせれば2FA。**PKI自体が2FAを意味するわけではない。**

NISTデジタルアイデンティティモデル



重要：Claimantは「認証を試みる役割」、Subscriberは「CSPに登録された役割」。**認証に成功した瞬間に初めてSubscriberになる、という理解は不正確。**CSP、Verifier、RPは構成によって同一組織内にも分離しても存在する。

関連規格：NIST SP 800-63（デジタルIDガイドライン、版による改訂あり）、ISO/IEC 27001/27002（アクセス制御）、ISO/IEC 24760（アイデンティティ管理）。教材の「SP 800-863」は**SP 800-63の読み違いと考えられる。**

5.2.4 認証（Authentication）と認可（Authorization）

概念	意味	銀行業務の例
身元証明（Identity Proofing）	**登録時**に実在する本人の身元を確かめる	入社時に本人確認書類を照合
識別（Identification）	IDを名乗る	社員番号を入力
認証（Authentication）	名乗った主体が正しいか確認	パスキー、カード、MFAでログイン
認可（Authorization）	**その操作が許されるか**決定	顧客DBの閲覧権限はあるが更新権限はない
アカウンティング（Accounting）	操作を記録し追跡可能にする	いつ誰が顧客情報を閲覧したか監査

認可の2つの意味：

1. **事前の権限付与**：データオーナーが「社員Aに口座照会権限を与える」と決定。
2. **実行時の認可判定**：実際の照会要求に対して、ID・対象・操作・状況を照合して許可／拒否。

出社の例：敷地ゲート→建物のICカード→PCログイン→メール→顧客DBと複数の認証・認可が連続する。毎回必ずパスワードを入力するわけではなく、既存セッション・SSO・条件付きアクセスなどを活用。

セルフサービスアイデンティティ管理

ユーザーが管理者の手作業を待たずに、**認められた範囲でID属性・認証器・アクセス申請を管理**する仕組み。

操作	例	安全な実装上の注意
認証情報の更新	パスワード、パスフレーズ、PINの変更、認証器の追加	本人再確認、強固な復旧手順
属性の更新	住所、電話番号、連絡先	重要属性は検証や承認を要求
アクセス申請	サーバー、エクストラネット、文書リポジトリ	**申請と承認は別。**上長/データオーナー承認
アプリ利用申請	新しい業務アプリ・プラットフォームのアカウント	最小権限、職務分掌、期限付き権限
アカウント復旧	紛失した認証器の再登録	ソーシャルエンジニアリング対策

チャレンジ質問は従来の仕組みだが、推測・漏えいの問題があり現代の高保証な認証・復旧には不向き。

5.2.5 アカウンティング（Accounting）

システムに登録されたIDに紐づく操作を**記録・追跡・監査**する機能。認証成功/失敗、アクセス先、操作内容、時刻、端末、結果、権限変更などを記録する。定期ステータスレポートや監査証跡、インシデント調査に利用。ログの改ざん防止・時刻同期・保存期間・アクセス権限も重要。

5.2.6 パスワードレス認証

パスワードをサーバーに提示せず、登録済みの公開鍵などで認証する方式。代表例は**FIDO2/パスキー**。端末側の秘密鍵を生体認証やPINで解錠し、サーバーのチャレンジへ署名して応答する。

- **利点**：パスワード再利用・漏えい・フィッシングのリスク低減（特にオリジンに紐づくFIDO2）。
- **注意**：認証器の紛失・復旧、同期型パスキーのアカウント保護、端末侵害、セッション乗っ取りは別途対策が必要。
- **混同注意**：「パスワードレス＝必ずMFA」ではない。認証器の特性とユーザー検証方法を評価する。

5.2.7 セッション管理（Session Management）

ログイン後の複数リクエストを**同一の認証済み主体に安全に結び付け、権限とセッションの有効性を維持する**仕組み。銀行ならログイン→残高照会→振込確認→ログアウトまでの一連の通信。

1. 認証成功後、サーバーが**推測困難なセッションID**または適切なトークンを発行。
2. ブラウザーがCookie等でセッション識別情報を保持。
3. 各要求で有効期限、認証状態、権限、必要なら端末・リスクを確認。
4. ログアウト・失効・タイムアウト・高リスク操作時の再認証を実施。

対策：TLS、Cookieの`Secure`・`HttpOnly`・`SameSite`、ログイン時のID再生成（セッション固定攻撃対策）、アイドル/絶対タイムアウト、CSRF対策、セッション失効、異常検知。**セッションIDは推測困難な乱数値だが、常に1回限りで使い捨てるNonceとは異なる。**また、Webセッション管理をOSI第5層のプロトコルだけで説明するのは不正確で、実際にはHTTP・Cookie・アプリケーション層の仕組みを利用する。

教材の規格に関する注意：RFC 2965は古いHTTP Cookie仕様。現在はRFC 6265系が重要。OWASP Top 10の「Broken Authentication and Session Management」が**常に第2位というわけではない**（ランキング・名称は版により変わる）。X.509証明書はTLS/クライアント認証などに利用できるが、**証明書だけでセッション管理が完結するわけではない。**

5.2.8 IAM実装とISOアイデンティティモデル

IAM導入の難所は技術導入そのものより、**組織のポリシーを実際の登録・権限付与・変更・退職処理へ落とし込むこと。**最初に業務要件、資産分類、権限所有者、リスク、既存ID基盤、監査要件を把握する。

規格	主な対象
ISO/IEC 24760シリーズ	アイデンティティ管理の用語・概念、アーキテクチャ、実務的枠組み
ISO/IEC 29100	プライバシーフレームワーク
ISO/IEC 29003	身元証明・検証
ISO/IEC 27001/27002	ISMS・セキュリティ管理策。アクセス制御を含む

版の注意：ISO/IEC 27001:2013のAnnex A.9はアクセス制御だったが、**2022年版では管理策の構成が再編**されている。「FDIS」は最終国際規格案の段階を示す表記で、現行版番号と混同しない。

5.2.9 フェデレーションID管理（FIM）

FIM（Federated Identity Management）は、異なる組織・サービス間で信頼関係を作り、認証結果や必要な属性を安全に連携する管理方式。

用語	意味	銀行の例
IdP（Identity Provider）	認証を行い結果を提供	銀行の共通認証基盤
SP（Service Provider）	SAML等で認証結果を受けサービス提供	外部の経費精算サービス
RP（Relying Party）	認証結果を信頼して利用	OIDC連携先の業務アプリ
Identity Store	ID・属性を保管	銀行のAD/ディレクトリ
Assertion（アサーション）	認証や属性に関する表明	SAML署名付きXML
Federated IdP	組織間の連携に参加するIdP	外部サービスと連携する銀行のIdP

典型的なSAML型SSOフロー：

1. 銀行社員が外部経費精算サービス（SP）へアクセス。
2. SPが信頼済みの銀行IdPへブラウザーをリダイレクト。
3. IdPがIdentity Store等を参照し、本人認証（必要ならMFA）。
4. IdPが署名付きアサーションを発行。
5. ブラウザー経由でSPがアサーションを受信し、**署名・発行者・Audience・有効期限・再利用防止**等を検証。
6. SPがローカルの権限を確認し、セッションを作成してアクセスを許可。

OIDCの場合：OAuth 2.0の認可コードフロー等でIDトークンを取得・検証する。**SAMLアサーションとOIDC IDトークンは別の形式**。また**認証成功＝無制限の認可ではない**。

5.2.10 単一要素認証（SFA）と多要素認証（MFA）

認証要素	意味	例
知識（Something you know）	本人だけが知る	パスワード、PIN
所持（Something you have）	本人が持つ	ICカード、セキュリティキー、登録スマートフォン
生体（Something you are）	身体的特徴	指紋、顔、虹彩

構成	判定	理由
パスワードのみ	**SFA**	知識1種類
パスワード＋秘密の質問	**MFAではない**	どちらも知識
ICカード＋PIN	**2FA/MFA**	所持＋知識
パスワード＋スマートフォン認証アプリ	**MFA**	知識＋所持（実装による）
セキュリティキー＋PIN	**MFAになり得る**	所持＋知識
パスキー＋端末上の生体認証	**MFAになり得る**	鍵の所持＋ユーザー検証（方式・保証要件による）

重要：2ステップだから必ず2要素とは限らない。SMS認証はSIMスワップ等のリスクがあり、フィッシング耐性の高いFIDO2を優先する場面が多い。

5.2.11 アクセス制御トークンとアイデンティティ保証レベル

物理・論理トークン

分類	主な用途	例
物理セキュリティトークン	物理空間への入場・アクセス制御	社員証、IC入館カード、鍵付き認証デバイス
論理アクセストークン	システム・API・アプリへのアクセスや認証結果の伝達	OAuthアクセストークン、セッショントークン、Kerberosチケット

※「物理的なデバイスか／デジタル文字列か」と「何へのアクセスを制御するか」は必ずしも同じ分類ではない。**USBセキュリティキーは物理デバイスだが論理アクセスの認証器**になり得る。

NIST SP 800-63：IAL・AAL・FAL

保証レベル	何を評価する？	概要
IAL（Identity Assurance Level）	登録時の**身元証明の確かさ**	IAL1：自己申告ベース、IAL2：規定の証拠確認・検証、IAL3：より厳格な証明・本人との結び付け
AAL（Authenticator Assurance Level）	ログイン時の**認証の強度**	AAL1：単一/複数要素の認証、AAL2：多要素、AAL3：高度な認証器・フィッシング耐性等の強い要件
FAL（Federation Assurance Level）	IdPからRPへの**連携・アサーション保護の強度**	FAL1〜3：アサーション保護・鍵・結び付け等の要件が強化

銀行の例：口座開設時の本人確認が**IAL**、ネットバンキングへのログインが**AAL**、銀行のIdPが外部サービスへ認証結果を安全に渡すことが**FAL**。

版の注意：NIST SP 800-63は改訂があるため、IAL3の対面要件などは**特定版の記述をそのまま全版に一般化しない**。重要なのは3つが異なるリスクを測ること。

5.2.12 SSO（Single Sign-On）

SSOは一度の認証で、再度資格情報を入力せずに複数サービスへアクセスできる仕組み。**SSOはユーザー体験・認証連携の仕組み、FIMは組織間の信頼・ID連携の管理**であり、両者は重なるが同義ではない。

方式	イメージ	注意
古典的な資格情報保管型SSO	中央保管庫がアプリごとのID/パスワードを管理・代行入力	秘密情報の集中保管、同期・変更対応
チケット型SSO	Kerberosで認証済みチケットを使う	KDCへの依存
フェデレーション型SSO	SAML/OIDCでIdPの認証結果をSP/RPが信頼	署名・Audience・有効期限の検証が必須

3つの主な課題：

1. **レガシーシステム**：標準連携非対応で個別開発・代理入力が必要。

2. **単一障害点・集中リスク**：IdP障害で多くの業務アプリへログインできない。IdP侵害で広範囲へ影響。冗長化・非常用アクセス・MFAが必要。
3. **パスワード同期**：古典的なSSOや同期型構成では変更反映が問題になる。**SAML/OIDC型SSOでは各SPへパスワードを同期する必要がないことが多い。**

5.2.13 アクセス制御のエラー：FRR・FAR・CER/EER

指標	意味	例	主な影響
FRR（False Rejection Rate）	正規利用者を誤って拒否する割合	正しい社員の指紋が通らない	可用性・利便性の低下
FAR（False Acceptance Rate）	非正規利用者を誤って受け入れる割合	別人の顔が本人と判定される	機密性・完全性のリスク
CER / EER（Crossover / Equal Error Rate）	FRRとFARが等しくなる運用点の誤り率	閾値を調整して2曲線が交差	比較用の性能指標。**必ずしも最適運用点ではない**

トレードオフ：認証閾値を厳しくすると通常**FAR↓・FRR↑**、緩くすると**FAR↑・FRR↓**。銀行の高額送金ならFAR低減を重視する一方、救急医療等では誤拒否の影響も大きい。**Type I＝FRR、Type II＝FAR**という対応は教材の文脈に沿うが、統計学一般のType I/IIとの混同に注意。

5.2.14 JITアイデンティティ・JITアクセス

Just-in-Time（JIT）は必要なときに、必要な期間だけIDや権限をプロビジョニングし、終了時に取り消す考え方。JITアイデンティティ（オンデマンドID作成）とJIT特権アクセス（既存IDへの一時権限付与）は区別できる。

例：銀行の本番DB障害対応

1. エンジニアは通常、管理者権限を持たない。
2. 障害対応のため1時間だけ特権アクセスを申請。
3. チケット、承認、MFA、端末状態などを検証。
4. 必要なDB管理権限を一時付与（**権限昇格**）。
5. 操作を記録・監視し、終了時・期限到来時に権限を自動削除（**権限降格**）。

活用領域	例
PAM（Privileged Access Management）	管理者権限の期限付き付与
特権セッション管理	特権操作の記録・監視・セッション終了
エンドポイント特権管理	一時的なローカル管理者権限
リモートヘルプデスク	サポート担当の一時アクセス
非人間ID	バッチ処理に短期トークン・一時資格情報を発行

製品・サービス例：Microsoft Entra Privileged Identity Management（PIM）、AWS STSの一時クレデンシャル、Okta等のID連携・ライフサイクル管理、Salesforceの権限管理（各製品でJITの実現範囲は異なる）。

重要：**JIT ≠ JEA（Just Enough Administration）**。JITは**時間の最小化**、JEAは**権限範囲の最小化**。両方を組み合わせるのが望ましい。

5.2 総合チートシート

混同しやすい概念	見分け方
身元証明 vs 認証	登録時に誰かを確認 vs 利用時に本人か検証
認証 vs 認可	誰かを確認 vs 何をしてよいか
IDM vs IAM	ID管理 vs ID管理＋アクセス管理
SSO vs FIM	一度のログインで複数サービス利用 vs 組織間の信頼・認証連携
IdP vs SP/RP	認証結果を提供 vs 検証・利用する
OAuth vs OIDC	委任認可 vs 認証レイヤー
IAL vs AAL vs FAL	身元証明 vs 認証強度 vs フェデレーションの強度
PKI vs CMS	証明書信頼基盤 vs 資格情報のライフサイクル管理
FAR vs FRR	他人を通す vs 本人を拒否
JIT vs 常設権限	必要な期間のみ vs ずっと保有

理解確認：

1. SAMLとOIDCはそれぞれどの情報をどう渡す？
2. 退職した社員のIDを無効化してもSP側の既存セッションが生きていたら何が問題？
3. 身元証明がIAL3でもログインが弱い場合、どの保証レベルを強化する？
4. パスワードと秘密の質問はMFAになる？
5. FARを下げるとFRRは通常どうなる？
6. JITアクセスで「必要な時間」と「必要な権限」を両方最小化するには？

> **収録範囲：Domain 5の概要、5.1〜5.6。** 5.1・5.2はアップロードされた原本に基づき、5.3〜5.6は今回の読み合わせを補足・整理した。

5.3 サードパーティーサービスとのフェデレーションID

目的：フェデレーションIDとサードパーティーサービスのセキュリティ上の考慮事項を評価する。

Federationは組織・サービス間の信頼関係を前提に、あるIdPの認証結果を別サービス（SP/RP）で利用すること。**IDaaS（Identity as a Service）**はID登録・プロビジョニング・認証・SSO・フェデレーション・ガバナンス等をサービスとして提供する。

項目	内容	具体例・留意点
プロビジョニング	人事イベントに連動したIDの発行・変更・廃止	退職時にSaaS側アカウントを停止
SSO・フェデレーション	SAML/OIDCで認証結果を連携	IdPが停止すると複数SaaSへの新規ログインに影響

項目	内容	具体例・留意点
リスク管理・評価	委託先リスク、監査、テスト	契約・SLA、監査報告書、インシデント通知
BCP/DR	認証基盤障害への備え	冗長化、緊急アクセス手順
機微情報の保護	ID・属性・認証ログの保護	データ所在、マルチテナント分離、保存・削除

形態	運用とデータ所在	長所	課題
オンプレミス	主に自社が管理、自社設備に保管	統制の自由度	CAPEX、保守人員、災害対策
クラウド	契約に従って事業者が運用、クラウドに保管	迅速な導入、設備投資削減	SLA、外部依存、マルチテナント、データ漏洩
ハイブリッド	自社と事業者が分担	既存ADとクラウドを連携	同期不整合、責任分界、複雑化

判断軸は2つ：①IAM管理者を雇用・監督するのは誰か（雇用関係か契約/SLAか）、②システムとAAA関連データはどこにあるか。**外部委託してもリスクの最終責任は組織に残る。**

5.4 認可の仕組みを実装・管理する

目的：アクセス制御モデルとメカニズムを比較する。

モデル	判断基準	具体例	試験のポイント
DAC（任意アクセス制御）	所有者の裁量	ファイル所有者が共有先を指定	柔軟だが過剰共有に注意
MAC（強制アクセス制御）	システムがセキュリティラベル・区分を強制	軍事機密区分、強制ポリシー	所有者が勝手に緩和できない
NDAC（非任意アクセス制御）	中央・組織が決定	全社共通のアクセス規程	DACと対照的な広い分類。MAC/RBACと重なることも
RBAC（ロールベース）	役割・職務	経理担当に支払処理権限	異動時のロール更新が重要
RuBAC（ルールベース）	事前定義のルール	休日のアクセス禁止、FWルール	RoleのRBACとRuleのRuBACを混同しない
ABAC（属性ベース）	主体・対象・操作・環境属性	部署＋端末状態＋時刻＋データ分類	動的で柔軟だが属性品質・設計が重要

リスクベースAC：接続元の異常、端末健全性、脅威情報などのリスクに応じてMFA追加・操作制限・拒否などの判定を変更する。例：通常端末では標準認証、不審な地域・端末からは追加認証。ABACと組み合わせられる。

アクセスポリシーの執行

要素	役割
PDP（Policy Decision Point）	許可／拒否を**決定**
PEP（Policy Enforcement Point）	PDPの判断を**執行**
PIP（Policy Information Point）	人事・端末などの属性情報を提供
PAP（Policy Administration Point）	ポリシーの定義・管理
コンテキストハンドラー	要求・属性・判断の受け渡しを調整

処理例：API要求→ゲートウェイ（PEP）→認可エンジン（PDP）が部署・端末状態等を評価→PEPが許可／拒否。**NIST SP 800-162**はABAC、**NIST SP 800-192**はアクセス制御システムの評価指標に関連する。

5.5 アイデンティティとアクセスプロビジョニングのライフサイクル

目的：IDの登録から廃止まで、アクセス制御と結び付けて管理する。

段階	主要な処理	例
身元確認・登録	実在性・所属・必要性を確認	入社時の本人確認
発行・プロビジョニング	ID作成と承認済み権限の付与	AD・SaaSアカウント発行
運用・行動監視	ログ、異常、権限逸脱を確認	不審な時間帯のアクセス
職務変更・レビュー	現職に合う権限へ更新	異動前権限の削除
無効化・プロビジョニング解除	不要な権限とセッションを停止	退職時の一括停止
保管・廃止	証跡の保持、保持期間後の削除	監査ログのアーカイブ

権限付与の職務分掌：上司等が申請→**データ／資産オーナーが承認**→**データカストディアン／IAM管理者が実装**→通知と監査記録。承認者と実装者を分ける。

Privilege Creep（権限クリープ）：異動・兼務のたびに権限が追加され、古い権限が残ること。定期的なアクセスレビューと職務変更時の権限再評価で防ぐ。

行動レビューでの検知例：権限超過の反復、未承認デバイス、設定管理の迂回、異常な入力によるアプリ悪用、通常と異なる時間帯の利用。**アカウントレビュー**では休眠ID・過剰権限・不要ID・権限不足を検出する。APTの長期潜伏を調査するためにも、改ざん耐性のあるログ保管が重要。

WindowsのSIDと組み込み主体

項目	意味
SID	Windowsのセキュリティ主体を識別する内部ID。表示名とは別
Administrator	ローカル組み込み管理者アカウント（典型的にRID 500）
Guest	組み込みゲストアカウント（典型的にRID 501）

項目	意味
DefaultAccount	Windowsが内部的に利用する組み込みアカウント
Domain Admins	ADドメインの特権**グループ**（典型的にRID 512）。ユーザーアカウントではない

権限昇格（Privilege Escalation）

- **垂直昇格**：一般ユーザーが管理者権限など上位権限を取得。
- **水平昇格**：同程度の権限を持つ他ユーザーの情報・操作へ不正アクセス（例：他人の注文履歴をID変更で閲覧）。
- **対策**：最小権限、アプリの認可検証、パッチ・脆弱性管理、MFA、IDS/IPS、SIEM、監査、教育。**MFAは認可欠陥を直接修正しない。**

IAAA（識別・認証・認可・アカウンティング／説明責任）はCIAに加え真正性、否認防止、プライバシー等を支える。認証されたユーザーでも認可されない操作は拒否する。

サービスアカウント：サービスやバッチ処理のための非人間ID。高権限・長期資格情報を放置しない。所有者、用途、権限、秘密情報の保護、ローテーション、監査、廃止を管理。

5.6 認証システムを実装する

目的：組織環境に適した認証・認可の仕組みを選択する。各技術は「目的→登場する構成要素→流れ→具体例→リスク」で理解する。

主要技術の比較

技術	主要目的	典型用途	キーワード
RADIUS	ネットワークアクセスAAA	VPN、企業Wi-Fi、802.1X	NAS、RADIUSサーバー、UDP 1812/1813
TACACS+	ネットワーク機器管理AAA	ルーターの管理者ログイン・コマンド制御	TCP 49、AAA分離
LDAP	ディレクトリ情報の検索・更新	AD・OpenLDAPのユーザー・グループ照会	DN、DIT、Bind、Search
Kerberos	チケットを用いたネットワーク認証	ADドメイン、社内SSO	KDC、AS、TGS、TGT
OAuth 2.0	APIアクセスの委任認可	外部API連携	Access Token、Scope、PKCE
OIDC	OAuth 2.0上の認証レイヤー	Web・モバイルログイン	OP、RP、ID Token、Claims
SAML 2.0	XMLアサーションによるフェデレーションSSO	企業SaaS	IdP、SP、Assertion

RADIUS（Remote Authentication Dial-In User Service）

構成要素：**Supplicant**（接続端末）、**Authenticator/NAS**（AP・スイッチ・VPN装置。RADIUSクライアント）、**RADIUS Server**（要求を評価するAAAサーバー）、必要に応じAD/LDAP等のIDストア。

フロー：端末がWi-Fiに接続要求→APがRADIUSへ**Access-Request**→サーバーが認証情報を検証→**Access-Accept／Reject／Challenge**→APが接続可否を執行→**Accounting-Request**等で記録。

一般に認証・認可は**UDP 1812**、記録は**UDP 1813**。旧来RADIUSはパケット全体の暗号化ではないため、通信経路保護やRADIUS over TLS等を考慮。RADIUSはIDデータベースそのものではない。

TACACS+（Terminal Access Controller Access-Control System Plus）

構成要素：管理者、TACACS+クライアント（ルーター等）、TACACS+サーバー、認証・認可・アカウンティングの各処理。

フロー：管理者がルーターへログイン→ルーターがサーバーへ認証照会→ログイン後にコマンド実行の認可を個別照会→実行内容を記録。

通常**TCP 49**。RADIUSがネットワーク接続管理でよく使われるのに対し、TACACS+は**機器管理とコマンド単位の認可**で強み。従来の保護方式を現代的なTLS暗号化と同一視しない。

LDAP（Lightweight Directory Access Protocol）

構成要素：**Directory Server**（ディレクトリサーバー）、**Entry**（ユーザー等のレコード）、**Attribute**（cn、mail等）、**DN**（識別名）、**DIT**（階層構造）、**Bind**（接続時の認証）、**Search**（検索）。

例：`uid=tanaka,ou=people,dc=example,dc=com`はユーザーのDN。アプリがLDAPサーバーにBind→部署・所属グループをSearch→アプリが認可判断。通常TCP 389、LDAPSは636。TLSで保護する。**LDAPはディレクトリ操作プロトコルであり、Kerberosのようなチケット認証やSAML型SSOそのものではない。**

OAuth 2.0（委任認可）

用語	役割
Resource Owner	対象データの権限を持つ主体
Client	APIアクセスを要求するアプリ
Authorization Server	認可を処理してトークンを発行
Resource Server	保護対象のAPIを提供
Access Token	APIアクセス用の資格情報
Scope	許可範囲
Authorization Code / PKCE	認可コードフローを安全に実施するための要素
Refresh Token	必要に応じ新たなアクセストークンを取得

例：家計簿アプリに銀行の「取引照会のみ」を委任。利用者が認可→アプリが認可コードを取得→トークン交換→APIへアクセストークン提示。**OAuth 2.0単独はログイン認証の規格ではない。**

OpenID Connect（OIDC：認証）

OIDCはOAuth 2.0上でユーザー認証を扱う。**OP（OpenID Provider）**が認証し、**RP（Relying Party）**が結果を利用。**ID Token**は認証結果を表すトークン（通常JWT）、**UserInfo Endpoint**はユーザー属性を取得するAPI。

クレーム	意味
`iss`	発行者
`sub`	ユーザー識別子
`aud`	対象クライアント
`exp`	有効期限
`iat`	発行時刻
`auth_time`	認証時刻（条件により含まれる）
`nonce`	要求と応答を結び付ける値

フロー：RPがOPに認証要求→OPで本人認証→認可コード発行→RPがトークンを取得→IDトークンの署名・`iss`・`aud`・`exp`・`nonce`等を検証→ログイン。**IDトークンは認証、アクセストークンはAPIアクセス**。両者を混同しない。

Kerberos（チケット認証）【重点】

要素	正式名称・役割
KDC	Key Distribution Center。認証とチケット発行の中心。AS/TGSの論理機能を提供
AS	Authentication Server。初期認証とTGT発行
TGS	Ticket Granting Server。サービスチケット発行
TGT	Ticket Granting Ticket。サービスチケットを要求するためのチケット
Service Ticket	特定サービスに提示するチケット
Principal	ユーザー・サービス等のKerberos上の主体
Realm	認証管理・信頼の論理的な範囲
Session Key	認証・通信保護に使う一時鍵
Authenticator	チケット提示時に主体と要求の新鮮さを示す情報

認証フロー：

1. **AS-REQ**：クライアントがASにTGTを要求（必要に応じ事前認証）。
2. **AS-REP**：ASがTGTとセッション鍵情報を返す。TGTはTGSが検証できるよう保護される。
3. **TGS-REQ**：TGTとAuthenticatorを使い、対象サービス用のチケットを要求。
4. **TGS-REP**：TGSがサービスチケットとセッション鍵情報を発行。
5. **AP-REQ**：クライアントがサービスチケットとAuthenticatorをサービスに提示。
6. **AP-REP（任意）**：相互認証に利用。サービスは別途認可を実施。

具体例：ADドメイン参加PCでログイン→ドメインコントローラー（KDC）からTGTを取得→ファイルサーバー用サービスチケットを取得→SMBサービスが検証。**サービスごとにパスワードを送らずに認証できる。**

欠点と対策：

- **KDCが単一障害点／重要な信頼基盤**：物理・論理的保護、冗長化、バックアップ、BCP/DR。
- **パスワード由来の鍵への攻撃**：弱いパスワード、推測、Kerberoasting等に備え強い秘密情報と適切な暗号方式。
- **チケットの盗用・再利用**：有効期限、端末保護、監査、時刻同期、リプレイ対策。
- **誤解注意**：Kerberosは認証基盤。全アプリ通信の暗号化やリソースへの最終認可まで自動保証するわけではない。

SAML 2.0（Security Assertion Markup Language）【重点】

3つのロール

ロール	役割	例
IdP（Identity Provider）	ユーザーを認証し、アサーションを発行	Entra ID、Okta
SP（Service Provider）	アサーションを検証しサービスを提供	Salesforce等
User Agent	IdPとSPの間のメッセージ移送を仲介	Webブラウザ

※**RP**は主にOIDCの呼び方。SAMLでは**SP**が標準的。

4つのコンポーネント

コンポーネント	役割	覚え方
Assertion	認証・属性・認可判断の表明	**何を伝えるか**
Protocol	AuthnRequest/Response等の交換ルール	**何を要求しどう応答するか**
Binding	HTTP Redirect、HTTP POST等の転送方法	**どう運ぶか**
Profile	特定用途での組合せ	**どう使うか**

Assertionの代表的なステートメント：**Authentication Statement**（認証結果）、**Attribute Statement**（部署等の属性）、**Authorization Decision Statement**（アクセス判断に関する表明）。一般的なSSOではSP側が自身の認可ポリシーも適用する。

SP開始SSOの流れ：

1. 社員が業務SaaS（SP）にアクセス。
2. SPが**AuthnRequest**を作成し、ブラウザ経由でIdPへ誘導。
3. IdPが認証（必要に応じMFA）。
4. IdPが署名付き**SAML Response／Assertion**を生成し、ブラウザ経由でSPへ送る。
5. SPが**署名・発行者・Audience・宛先・有効期限・InResponseTo・再利用防止**などを検証。
6. SPがログインセッションを作成し、権限に応じてサービス提供。

具体例：Entra IDで認証しSalesforceへSSO。Salesforceに社内パスワードを渡さずに済む。**リスク**：署名検証不備、アサーション再利用、証明書更新漏れ、IdP侵害・停止。

IDaaSの監査・コンプライアンスレポート

カテゴリー	代表的な機能	監査・統制の観点
IGA（Identity Governance and Administration）	IDライフサイクル、権限申請・承認、棚卸し、SoD	誰が何を承認・変更したか
Access	SSO、MFA、認証・認可、SAML/OAuth等の連携	誰がいつどこからアクセスしたか
Intelligence	リスク分析、異常検知、レポート	不審ログイン、過剰権限、是正履歴

外部委託の判断：IAM管理者を誰が雇用・監督するか／AAAデータとソフトウェアはどこにあるか。SLAと契約、データ所在、サービス停止時の業務影響を評価。

Domain 5 最終チートシート

設問のキーワード	想起する概念
「身元の確かさ／ログイン強度／連携の強度」	IAL／AAL／FAL
「他人を通す／本人を拒否」	FAR／FRR
「必要な時間だけ特権」	JIT、PAM
「所有者がアクセスを設定」	DAC
「中央のラベルで強制」	MAC
「役職で付与／属性で動的判定」	RBAC／ABAC
「判断する／実行する」	PDP／PEP
「権限を承認／技術的に設定」	データオーナー／カストディアン
「異動前の権限が残る」	Privilege Creep
「ネットワーク接続AAA／機器管理AAA」	RADIUS／TACACS+
「ディレクトリ検索／チケット認証」	LDAP／Kerberos
「API認可委任／ログイン認証」	OAuth 2.0／OIDC
「XMLアサーションによるSSO」	SAML

関連規格：NIST SP 800-63（デジタルID）、SP 800-162（ABAC）、SP 800-192（アクセス制御評価）、RFC 4120（Kerberos）、RFC 4511（LDAP）、RFC 2865/2866（RADIUS）、RFC 8907（TACACS+）、RFC 6749（OAuth 2.0）、OpenID Connect Core、OASIS SAML 2.0。

> 5.1・5.2はアップロードされた原本を保持。5.3〜5.6は今回の読み合わせをもとに、具体例・構成要素・処理フロー・試験上の注意点を補足して再構成した。